

User Authentication

Dr. Yiwen Hu

Brute-Force Attack

- Trying every possible combination

```
=====
USER AUTHENTICATION: HACKER CHALLENGE
=====
[?] Invite a student to type a 5 character secret.
Enter Secret (lowercase letters or digits only): 
```

- Scenario: 36-Character Set (a-z, 0-9).
- Speed: ~1-5 Million guesses/sec (Standard PC)
- How long can your five-character password withstand a brute-force attack before it cracks?

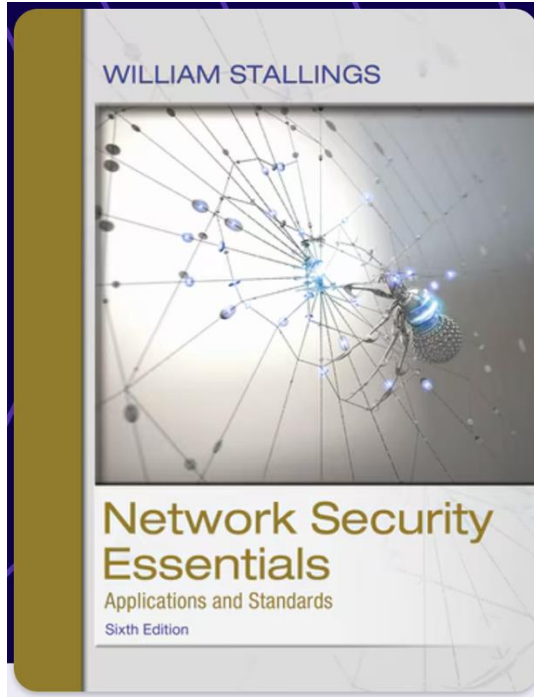
Brute-Force Attack

Password Length	The Math	Crack Time
5 Digits/Letters	60 Million	0.6 Seconds
6 Digits/Letters	2.1 Billion	21 Seconds
8 Digits/Letters	2.8 Trillion	Under 8 Hours
10 Digits/Letters	3.6 Quadrillion	About a Year

To beat a brute-force attacker, any good strategies?

- Increasing the password length
- ...

Acknowledgement



You can find it on Blackboard

The content of slides is from the textbook and Dr. Hu's supplementary materials

Reminder: Please do not post course materials online or share them with others without the instructor's permission

User Authentication

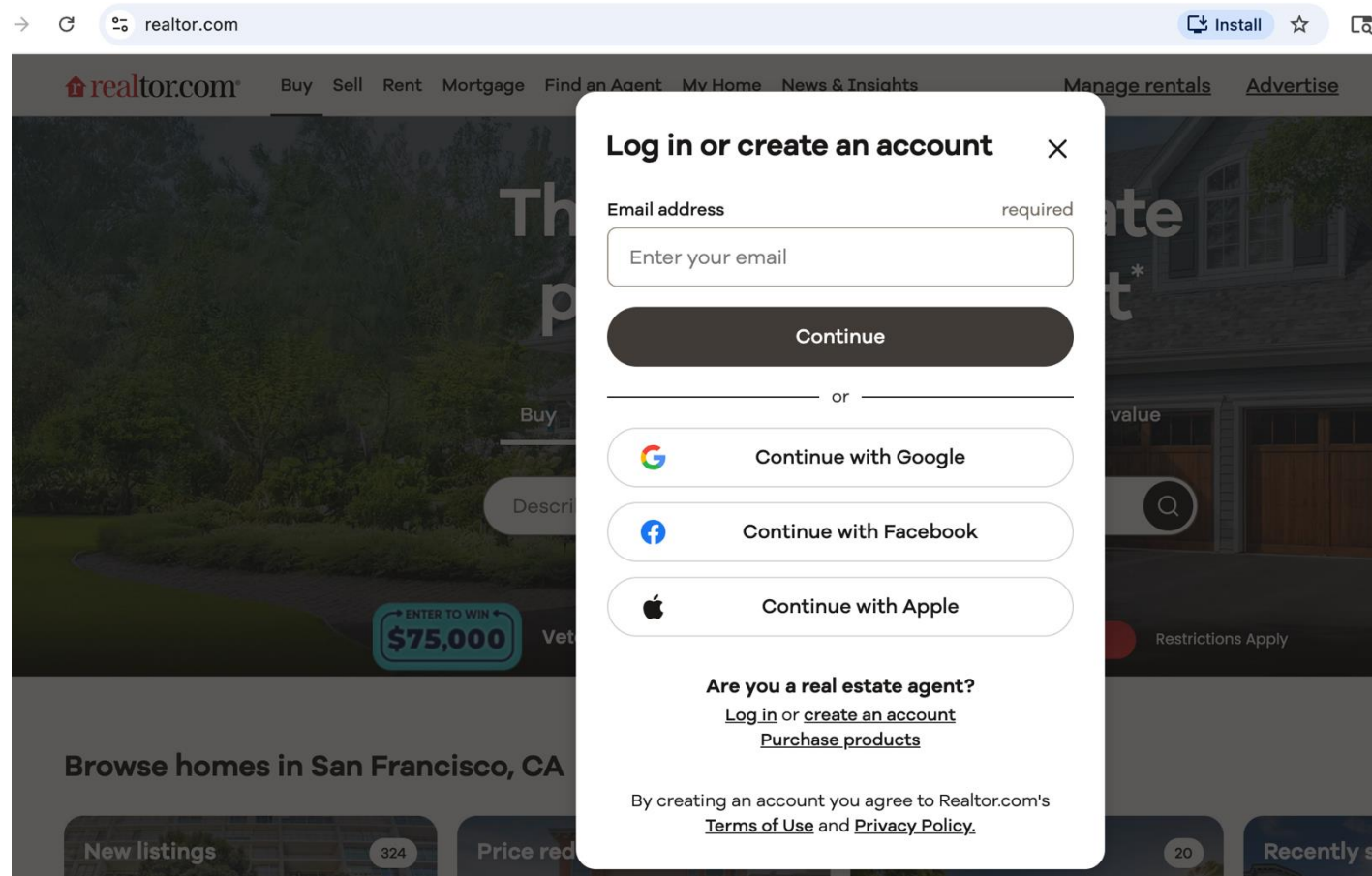
- It is the process of verifying an identity claimed by a system entity (e.g., a user).
- It is the primary line of defenses, and the basis for access control and user accountability
- Authentication process consists of two steps
 - **Identification step:** Presenting an identifier to the security system
 - **Verification step:** Verifying the authentication information that corroborates the binding between the entity and the identity
 - E.g., the entity is Alice, the identity is her username, Alice123, and, authentication information is her password, 12345678.

Overview

- Electronic user authentication model
- What you know
 - Password-based authentication
- What you have
 - Token-based authentication
- Who you are
 - Biometric authentication
- Remote user authentication
- Security issues for user authentication

Question

- Why can users log into Realtor.com using their Facebook/Google accounts?
- Will Realtor.com store and check your Facebook/Google address and password?



The image shows a web browser window with the URL `realtor.com`. A modal dialog titled "Log in or create an account" is displayed in the center. The modal contains the following elements:

- A close button (X) in the top right corner.
- A label "Email address" with a "required" note.
- A text input field with the placeholder text "Enter your email".
- A dark "Continue" button.
- A separator line with the word "or" in the center.
- Three social login buttons: "Continue with Google" (with Google logo), "Continue with Facebook" (with Facebook logo), and "Continue with Apple" (with Apple logo).
- A section titled "Are you a real estate agent?" with two links: "Log in or create an account" and "Purchase products".
- A footer note: "By creating an account you agree to Realtor.com's Terms of Use and Privacy Policy."

The background of the browser shows the Realtor.com homepage with a search bar, navigation links (Buy, Sell, Rent, Mortgage, Find an Agent, My Home, News & Insights, Manage rentals, Advertise), and a featured property listing in San Francisco, CA.

E-authentication Architecture Model

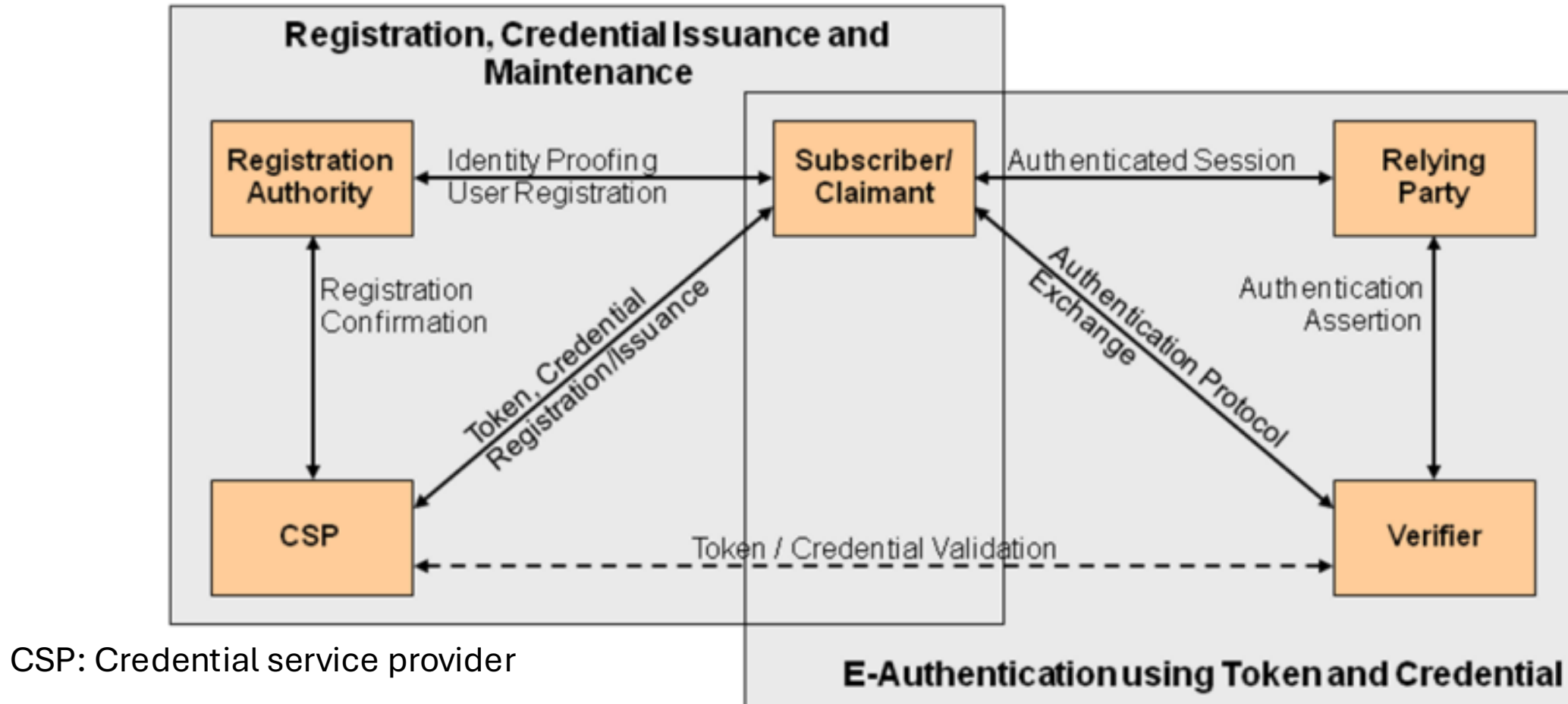


Figure 1 - *The NIST SP 800-63-1 E-Authentication Architectural Model*

Question

- Why can users log into realtor.com using their Facebook/Google accounts? Can it be mapped to E-authentication architecture model?

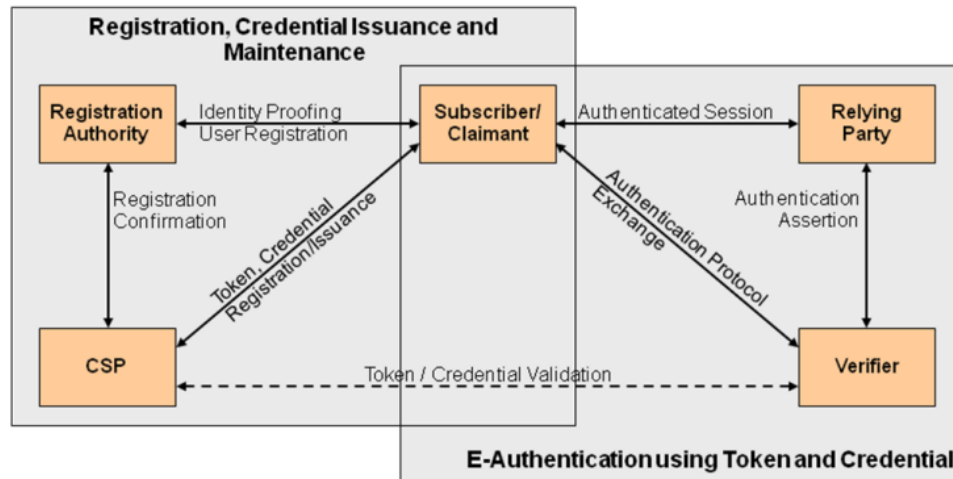
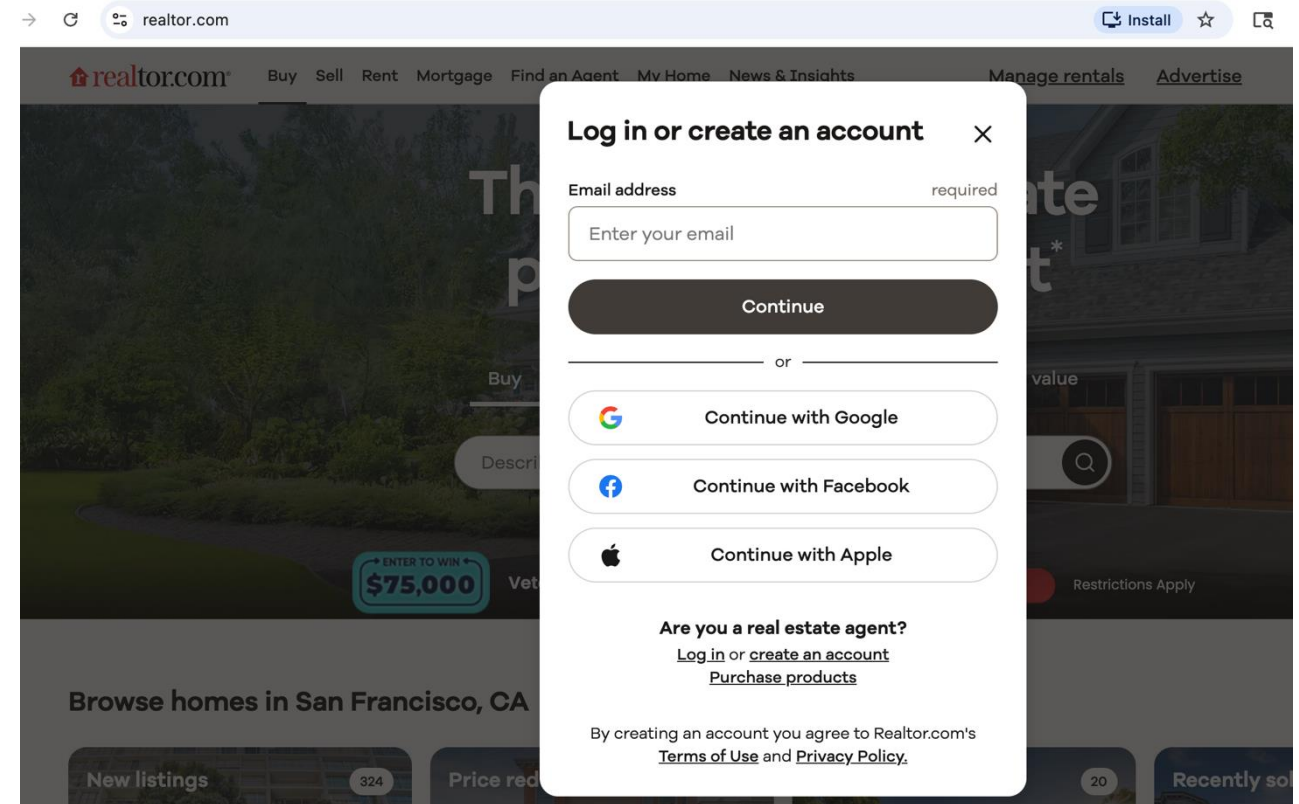


Figure 1 - The NIST SP 800-63-1 E-Authentication Architectural Model



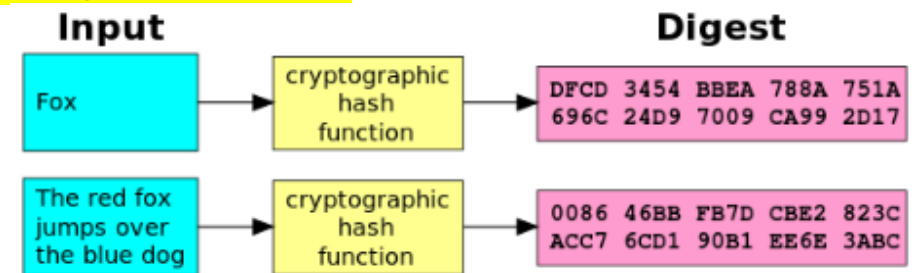


Password-based Authentication

-based on what you know

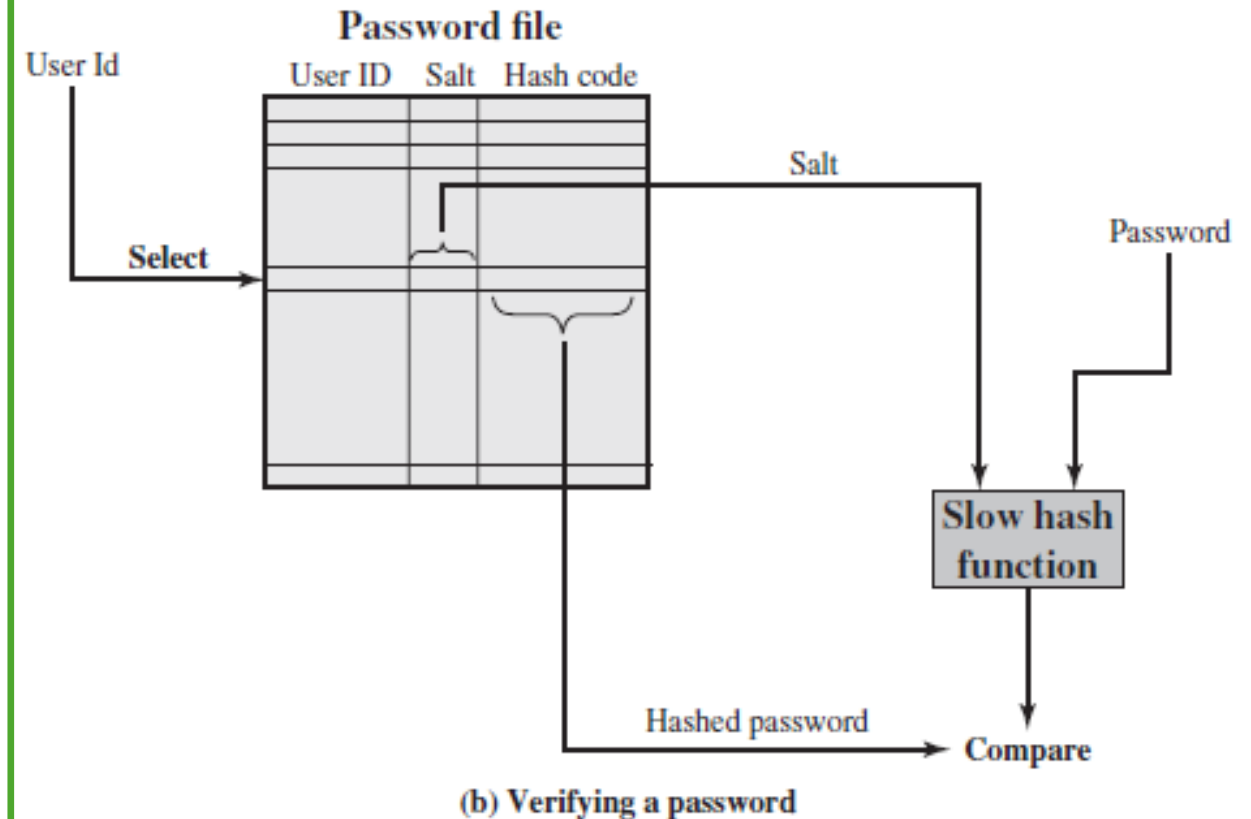
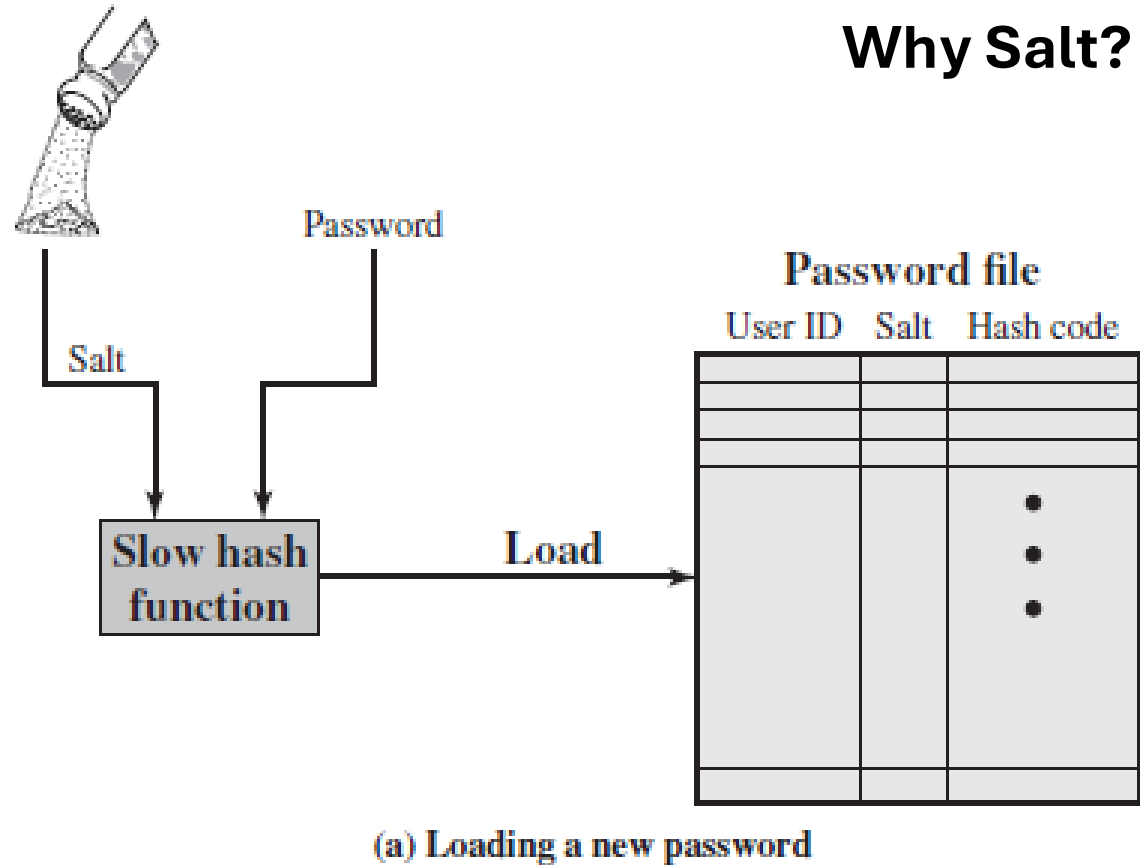
Password-based Authentication

- A widely used line of defense against intruders
 - A user provides a system with his/her name and password
 - System compares the password with the one stored for that specified login
 - System creates a password file to store usernames and the hashed values of passwords
 - Ideally, system administrators don't know users' passwords



- The user ID:
 - Determines that the user is authorized to access the system
 - Determines the user's privileges (e.g., superuser, guest)
 - Is used in access control (e.g., granting the permission to read file)

UNIX Implementation of password file



Traditional Password Attacks

- Dictionary attack
 - Prepare a large dictionary of possible passwords
 - Defense: use slow hash functions
- Dictionary + brute-force attack (assume that password file has been obtained)
 - Prepare a large dictionary of possible passwords
 - For each password, adversary **generates all possible salt values associated with it**, **pre-calculate** the hash values, and store the results into a table (rainbow table)
 - Use 1.4GB rainbow table to discover the alphanumeric Windows password in less than 220s
 - [Rainbow Tables & Rainbow Crack Introduction \(carnal0wnage.com\)](http://carnal0wnage.com)
 - Defense: use larger salt values and longer hash values

How to use pre-calculated table to discover password from a stolen password file?

Pre-calculated table (rainbow table)

Salt	Password	Pre-calculated hashed value
1	1234	345679
2	1234	556789
...	1234	789963

A stolen password file

User	Salt	Hashed Value
Alice	2	556789
Bob	56	996782
Cathy	78963	559998

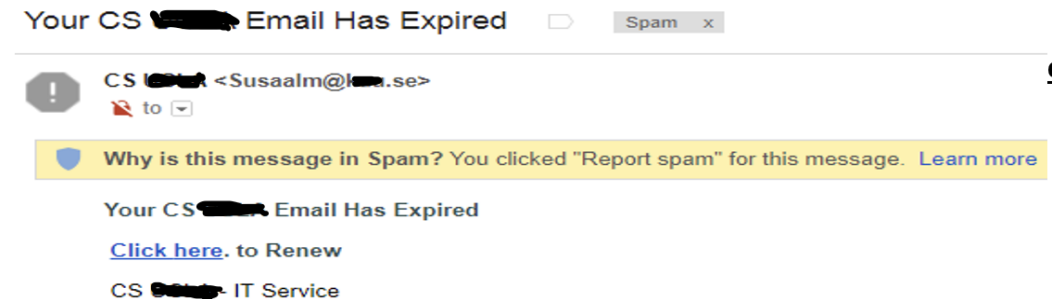
Other Password Attacks

- **Specific account attacks**

- Submit password guesses until the correct password is discovered or the account is blocked (fails more than 5 times) or password reset

- **Password sniffing/phishing**

- Passwords may be transmitted without encryption (e.g., ftp, telnet).
 - [Wireshark](#) can sniff packets;
- Phishing email – log into malicious sites





Token-based Authentication

-based on what you have

Token Authentication: Memory Card

- Can store but do not process data
- The most common is the magnetic stripe card
 - Can include an internal electronic memory
- Can be used alone for physical access
 - Hotel room, Campus Card, Gym Membership Card
- Provides significantly greater security when combined with a password or PIN (personal identification number) (differences)
- Drawbacks of memory cards include:
 - Loss of token
 - Requires a special reader (extra cost)
 - User dissatisfaction (inconvenient for computer use)



Token Authentication: Smart Cards

- Most important category of smart token
 - Has the appearance of a credit card
 - Has an electronic interface: Contact or contactless card reader
- Contains **an entire microprocessor**: Processor, Memory, I/O ports
- Typically include three types of memory:
 - **Read-only memory (ROM)**
 - Stores data that does not change during the card's life
 - **Electrically erasable programmable ROM (EEPROM)**
 - Holds application data and programs –can be reprogrammed
 - **Random access memory (RAM)**
 - Holds temporary data generated when applications are executed



Interaction Between Smart Card and Reader

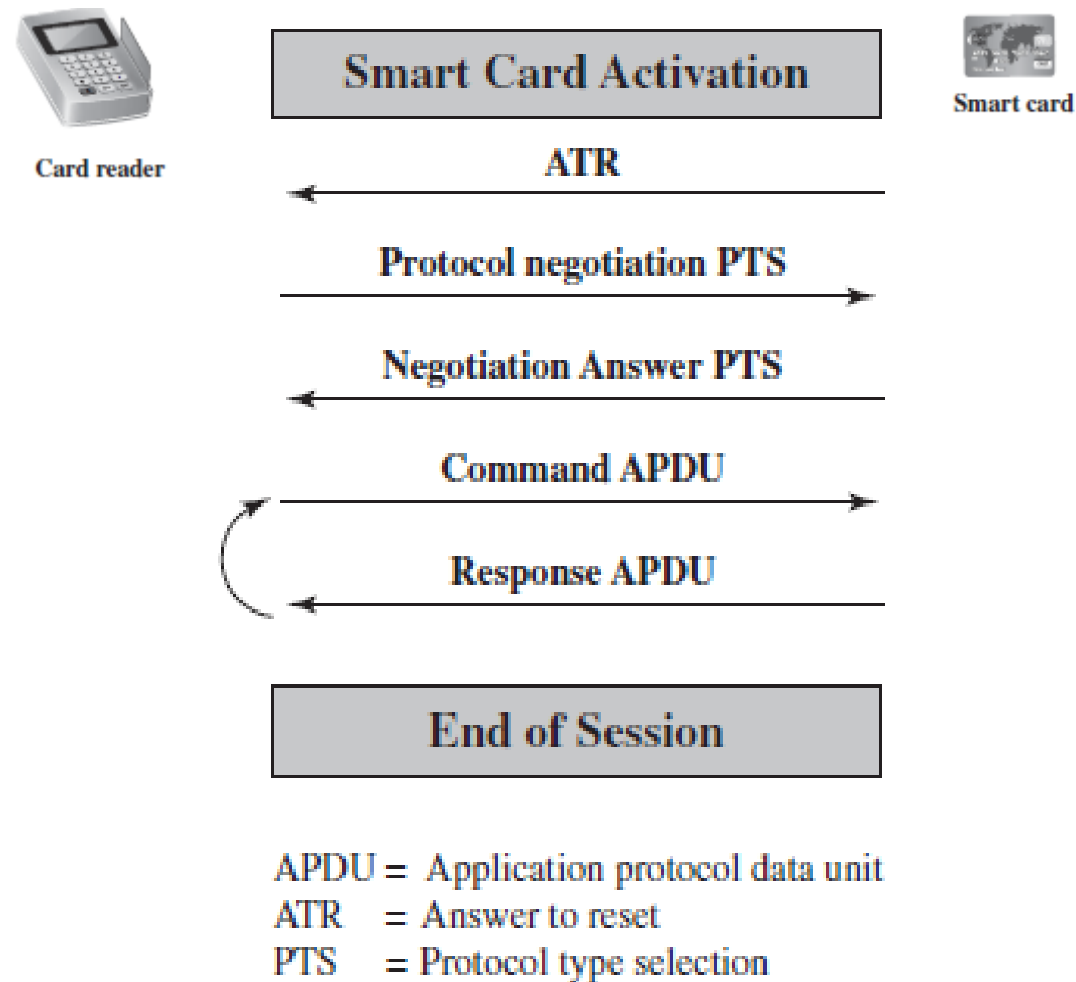


Figure 3.5 Smart Card/Reader Exchange

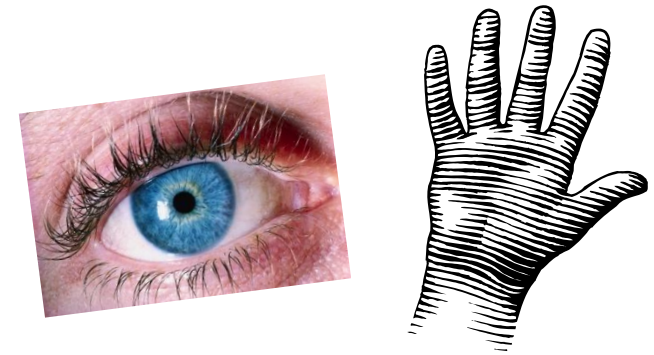


Biometric-based Authentication

-based on who you are

Biometric Authentication

- Attempts to authenticate an individual based on unique physical characteristics
 - Based on **pattern recognition**



- Physical characteristics used include:
 - Facial characteristics, Fingerprints, Hand geometry, Retinal pattern, Iris, Signature, Voice

Biometric Authentication

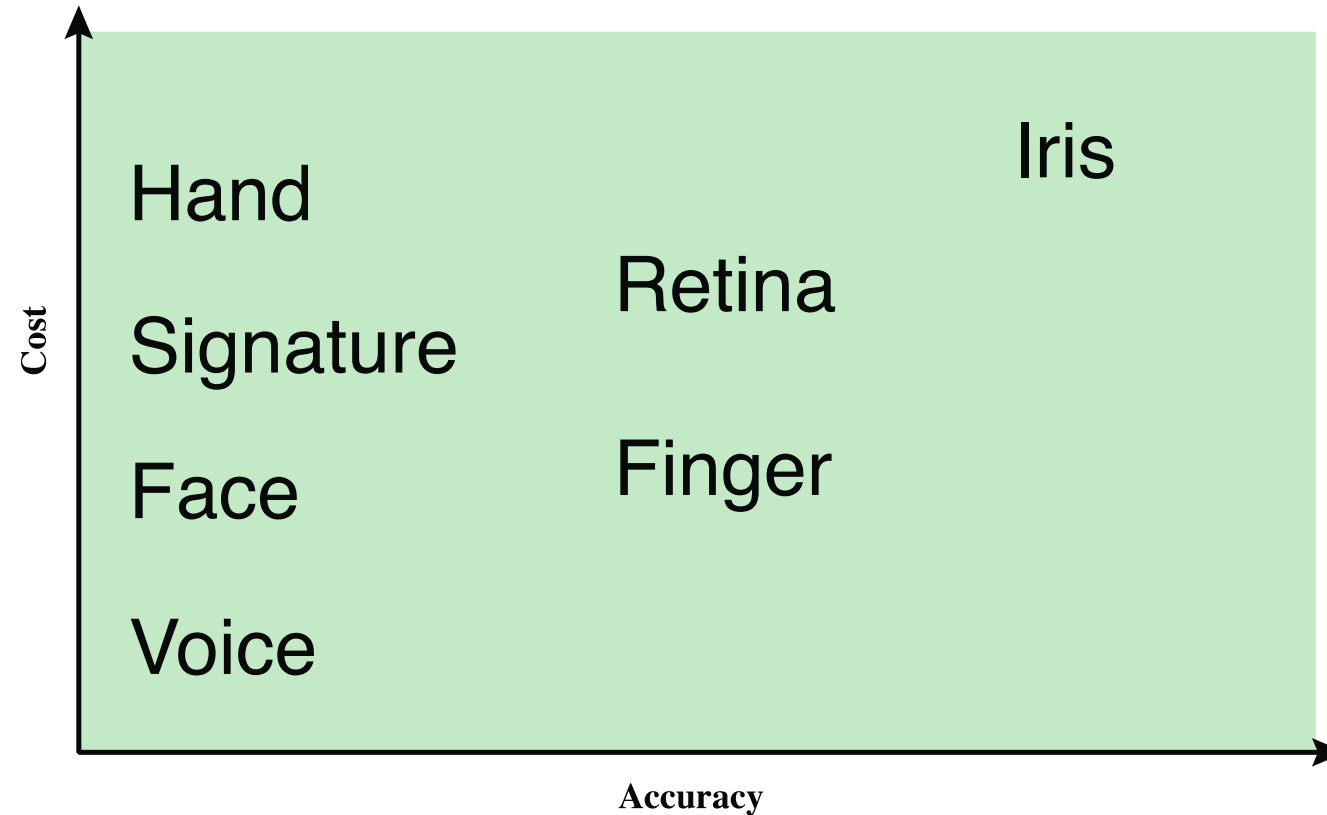


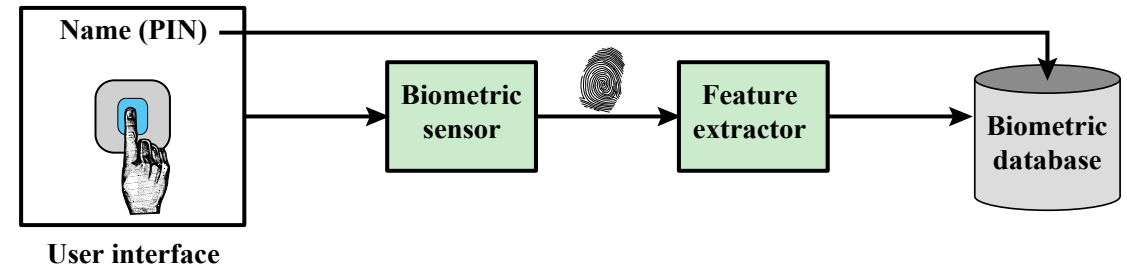
Figure 3.7 Cost Versus Accuracy of Various Biometric Characteristics in User Authentication Schemes.

Three operations of a Biometric Authentication System

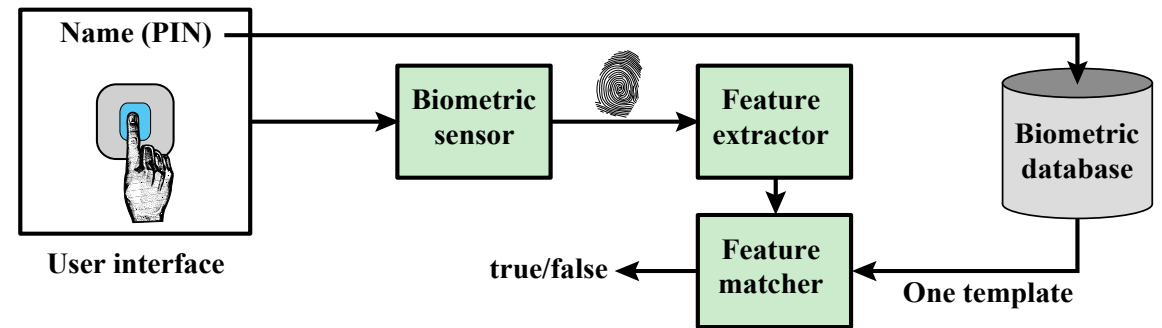
Enrollment is to enroll your biometric to the system

Verification is analogous to a user logging on to a system by using a smart card and a PIN

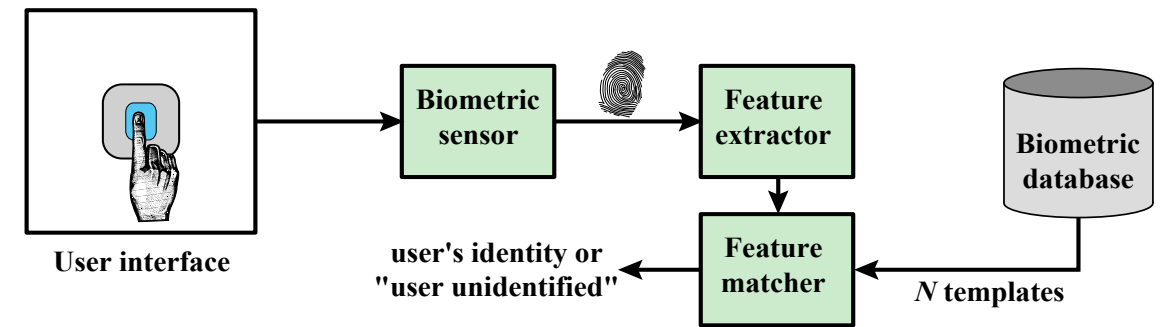
Identification is that user presents biometric info without other info; system compares it with stored templates



(a) Enrollment



(b) Verification



(c) Identification

Accuracy: False Match and False Nonmatch

False Match:
Accept imposters

False Nonmatch:
Reject genuine users

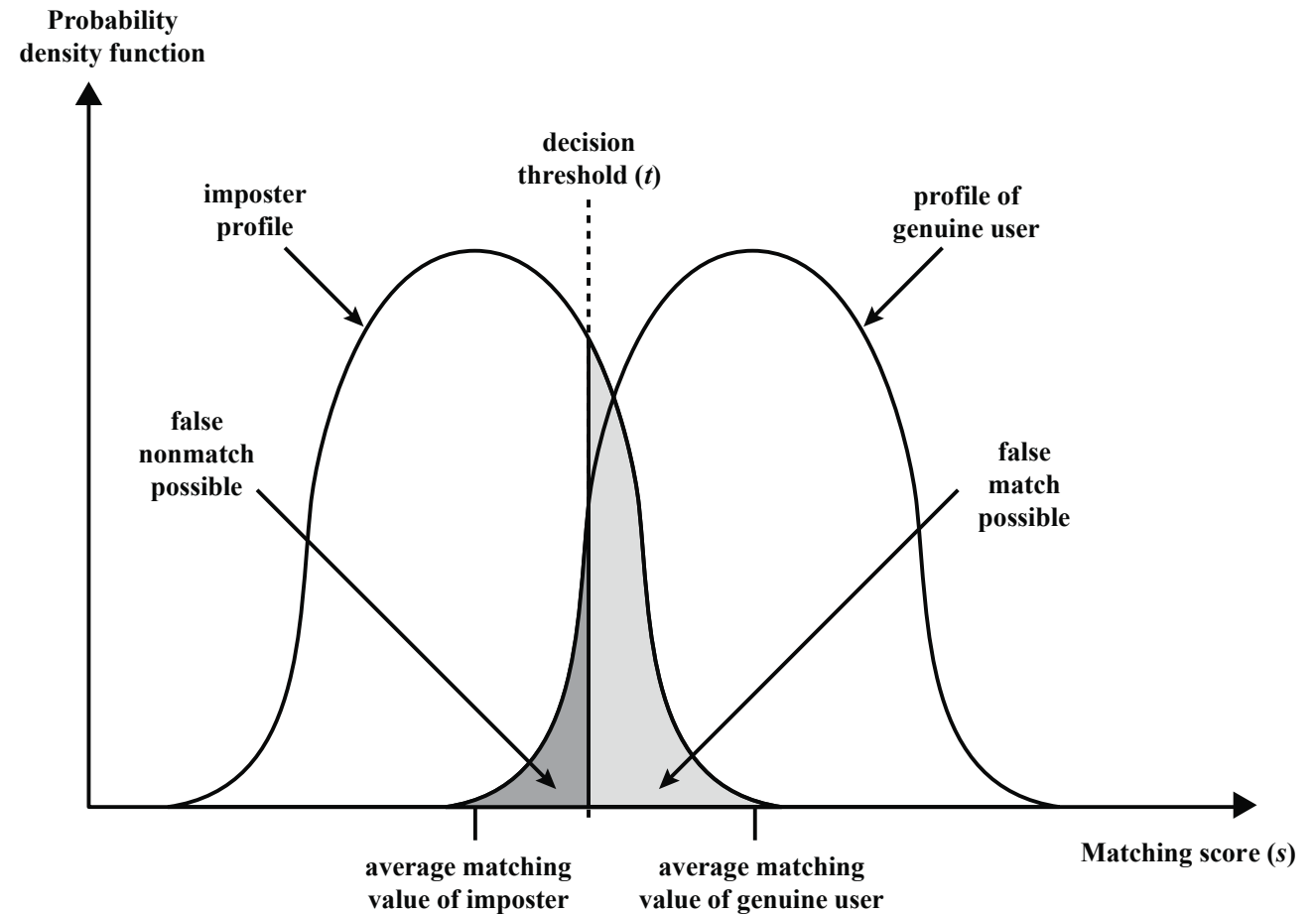


Figure 3.9 Profiles of a Biometric Characteristic of an Imposter and an Authorized Users In this depiction, the comparison between presented feature and a reference feature is reduced to a single numeric value. If the input value (s) is greater than a preassigned threshold (t), a match is declared.

Remote User Authentication

Remote User Authentication

- Authentication over a network, the Internet, or a communications link is more complex
 - Security threats are eavesdropping, capturing passwords, replaying authentication sequences that has been observed
- Generally, rely on challenge-response protocols
 - Protocol for a password
 - Protocol for a token
 - Protocol for static biometric
 - Protocol for dynamic biometric

Protocol for a Password Verification

1. User sends identity **U** to host
2. Host (i.e., server) responds with random number **r** (challenge), two hash functions **h** and **f**
3. User computes **f(r, h(P))** and sends it (response) back
4. Host computes **f(r, h(P(U)))** and compare it with the value user replied, $P(U)$ = password stored in the host

Client	Transmission	Host
U , user	$U \rightarrow$	
	$\leftarrow \{r, h(), f()\}$	random number $h(), f()$, functions
P ' password r' , return of r	$f(r', h(P)) \rightarrow$	
	$\leftarrow$ yes/no	if $f(r', h(P)) = f(r, h(P(U)))$ then yes else no

Token Protocol

1. user transmits identity U to the remote host
2. host returns a random number r and two hash functions: h and f
3. user obtains a one-time random W passcode from a token by providing his/her password
4. User sends $f(r, h(W))$ to the host
5. Host computes $f(r, h(W(P(U))))$ and compare it with the value user replied, where $W(P(U)) =$ one-time passcode derived from the user's password stored in the host



Client	Transmission	Host
U , user	$U \rightarrow$	
	$\leftarrow \{r, h(), f()\}$	r , random number $h(), f()$, functions
$P' \rightarrow W$ password to passcode via token r' , return of r	$f(r', h(W)) \rightarrow$	
	$\leftarrow$ yes/no	if $f(r', h(W)) =$ $f(r, h(W(U)))$ then yes else no

(b) Protocol for a token

**Example of a
token protocol**

Static Biometric Protocol

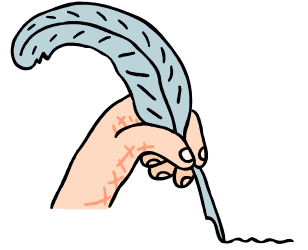
1. user transmits an ID to the host
2. host responds with a random number r and an encryption function E
3. client system controls biometric device on user side to encrypt $E(r, D, BT)$
4. host decrypts the message and compares BT to the stored template
If matching score exceeds threshold, user is authenticated

Client	Transmission	Host
U , user	$U \rightarrow$	
	$\leftarrow \{r, E()\}$	r , random number $E()$, function
$B' \rightarrow BT'$ biometric D' biometric device r' , return of r	$E(r', D', BT') \rightarrow$	$Decrypt(E(r', D', BT')) \Rightarrow r', D', BT'$
	$\leftarrow$ yes/no	if $r' = r$ and $D' = D$ and $BT' = BT(U)$ then yes else no

(c) Protocol for static biometric

**Example of a
static biometric protocol**

Dynamic Biometric Protocol



1. Similar to the static approach, but host provides **a random sequence** and a random number as a challenge
 - Random sequence challenge is a sequence of **numbers, characters, or words**
2. user at client end must then **vocalize** or **write** the sequence to generate biometric signals
3. the client side encrypts the biometric signals and the random number and sent it back to the host
4. host decrypts the message and generates a comparison

Client	Transmission	Host
U , user	$U \rightarrow$	
	$\leftarrow \{r, x, E()\}$	r , random number x , random sequence challenge $E()$, function
$B', x' \rightarrow BS'(x')$ r' , return of r	$E(r', BS'(x')) \rightarrow$	$E^{-1}E(r', BS'(x')) = (r', BS'(x'))$ extract B' from $BS'(x')$
	$\leftarrow$ yes/no	if $r' = r$ and $x' = x$ and $B' = B(U)$ then yes else no

Example of a
dynamic biometric
protocol



Security Issues for User Authentication

Security Issues for User Authentication

- **Eavesdropping:** attacker attempts to learn passwords by observing the user, finding written passwords, keylogging
 - **Countermeasures:** user multi-factors (e.g., password + smart card + biometric + temporary short codes via SMS)
- **Replay:** attacker repeats a previously captured user response
 - **Countermeasures:** add a random number or sequence number to challenge-response protocol

Security Issues for User Authentication

- **Trojan horse:** a **rogue application or physical device** (rogue ATM) masquerades as an authentic application or device to capture users' passwords, passcode or biometric.
 - **Countermeasures:** only perform user authentication **within a trusted security environment (e.g., only using ATM machines listed on banks' websites)**
- **Denial-of-service:** attacker attempts to disable authentication service via flooding – **possible high billing attacks**
 - **Countermeasures:** use a multitude of user authentication mechanisms, including token-based mechanism.

Summary

- **Electronic user authentication model**
- **Password-based authentication**
 - The vulnerability of passwords
 - The use of hashed passwords
 - Password cracking of user-chosen passwords
 - Password selection strategies
- **Token-based authentication**
 - Memory cards
 - Smart cards
- **Biometric authentication**
 - Physical characteristics used in biometric applications
 - Operation of a biometric authentication system
 - Biometric accuracy
- **Remote user authentication**
 - Password protocol
 - Token protocol
 - Static biometric protocol
 - Dynamic biometric protocol
- **Security issues for user authentication**